COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · DNS Attacks

Mestre CyberSec · **Lesson 2.4 — DNS Attacks** (8:57) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: DNS (o listado telefônico da rede): DNS spoofing/cache poisoning (resposta FALSA guardada em cache do resolver); Domain hijacking (rouba domínio no registrador); URL hijacking/typosquatting (registrar 'goggle.com'); DNS tunneling (esconde dado nas consultas DNS — exfiltra). Defes

💡 Key Exam Highlights & Critical Concepts

- DNS spoofing/cache poisoning: resposta FALSA guardada em cache
- Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing
- DNS tunneling: exfiltra dado escondido em queries DNS

🎯 Exam Tips & Typical CompTIA Scenarios

- 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning
- 'registers domain similar to legitimate one' = typosquatting

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — DNS Attacks)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Domain Name System (DNS)

Hierarchical naming system that translates human-readable domain names (e.g., example.com) into IP addresses. Functions as the 'phone book of the internet' and is a frequent target of attacks because compromising it redirects users transparently.

⚠ ***Exam Trap:*** *Any question involving name-to-IP resolution, resolvers, or authoritative servers — DNS is the underlying protocol being attacked.*

• DNS Spoofing / Cache Poisoning (N/A)

Attack where a forged DNS response is injected into a resolver's cache, causing future legitimate queries to return the attacker's IP. Victims are silently redirected to malicious servers without ever querying the real authoritative server.

⚠ ***Exam Trap:*** *Trigger phrase: 'fake DNS response directs user to attacker server' = DNS spoofing/cache poisoning. Distinguish from DNS amplification (a DoS attack on availability, not redirection).*

• Domain Hijacking (N/A)

Unauthorized takeover of a domain name registration, typically by stealing registrar credentials, exploiting registrar vulnerabilities, or manipulating DNS records at the registrar level. The attacker controls the entire domain, not just cached responses.

⚠ ***Exam Trap:*** *Look for wording like 'attacker changes nameservers at the registrar' or 'stolen registrar account' — that is domain hijacking, not cache poisoning (which is local to a resolver).*

• Typosquatting (URL Hijacking) (N/A)

Registering a domain name that is a common misspelling of a legitimate site (e.g., 'goggle.com', 'paypa1.com') to capture users who mistype URLs. Often used for phishing, malware distribution, or ad revenue.

⚠ ***Exam Trap:*** *Trigger phrase: 'registers a domain similar to a legitimate one' = typosquatting. Watch for character substitution patterns: rn↔m, 0↔o, 1↔l, adding/removing letters.*

• DNS Tunneling (N/A)

Technique that encodes data from another protocol or application inside DNS queries and responses to bypass network controls. Attackers use it primarily for data exfiltration or command-and-control (C2) communication since DNS traffic is rarely inspected.

⚠️ ***Exam Trap:*** *Trigger phrase: 'data hidden inside DNS queries' or 'exfiltration over port 53' = DNS tunneling. Look for unusually long TXT records or high volumes of DNS queries to a single domain.*

• DNSSEC (Domain Name System Security Extensions)

Suite of extensions to DNS that provides origin authentication and integrity through digital signatures (using DNSKEY and RRSIG records). Prevents cache poisoning and spoofing by cryptographically validating that responses come from the authoritative server.

⚠️ ***Exam Trap:*** *If a question asks 'how do you PREVENT DNS spoofing?' the answer is DNSSEC — do not confuse with DNS tunneling (an attack) or TLS/HTTPS (which encrypts but does not authenticate DNS responses).*

• DNS Resolver (Recursive Resolver) (N/A)

Server that performs recursive lookups on behalf of clients, querying root, TLD, and authoritative servers, then caching the result. Cache poisoning targets the resolver's cache to affect all users who query it.

⚠️ ***Exam Trap:*** *When a scenario mentions 'attacker poisons the cache of a DNS server used by many users,' the targeted component is the recursive resolver — not the authoritative server or the client.*

• Subdomain Takeover / Dangling DNS (N/A)

Attack where a DNS record (usually a CNAME) points to an external service (e.g., a cloud provider) that has been deprovisioned, allowing an attacker to claim that resource and serve content under the legitimate domain.

⚠️ ***Exam Trap:*** *Trigger phrase: 'DNS record still points to a service that no longer exists' = dangling DNS / subdomain takeover. Note that this exploits misconfiguration, not a DNS protocol flaw.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Evil Twin vs. Rogue Access Point

🏠 **Real-World Analogy:** A Rogue Access Point is like an employee sneaking a cheap home Wi-Fi router into the office, plugging it beneath their desk into a corporate Ethernet port to bypass network monitoring. An Evil Twin is an identity theft trap: a fraudster sets up a counterfeit coffee kiosk right outside an authentic Starbucks, branding it with the exact same 'Starbucks_Guest' SSID name and broadcasting with higher signal power so customer smartphones automatically roam onto the imposter network.

🔍 **Root Cause & Background:** Wireless clients prioritize known SSIDs based on signal strength (RSSI), blindly associating with the loudest access point. For rogue APs, unauthenticated switch ports lacking 802.1X allow employees to bridge untrusted wireless gear directly into the internal LAN.

🛡️ **GRC Auditor Perspective:** Deploy enterprise WIPS (Wireless Intrusion Prevention System) to continuously scan RF bands and contain unauthorized BSSIDs; mandate 802.1X authentication with digital certificates (EAP-TLS) and enable switch Port Security.

⚠️ **How CompTIA Tests This:** Trigger: 'unauthorized wireless device connected to a wired switch by an insider' -> Rogue Access Point. Trigger: 'fraudulent AP broadcasting an identical SSID with stronger signal strength to intercept traffic' -> Evil Twin.

📌 Deauthentication Attack & RF Jamming

🏠 **Real-World Analogy:** A Deauthentication Attack is like a prankster grabbing a megaphone outside an auditorium, mimicking the director's voice and shouting: 'Meeting canceled, everyone evacuate immediately!'. Confused attendees drop their connections; the attacker then points them toward the counterfeit auditorium next door (the Evil Twin). RF Jamming is like sounding a deafening air horn right in the room: electromagnetic noise completely drowns out speech, making wireless communication physically impossible.

🔍 **Root Cause & Background:** In legacy WPA2/802.11 architectures, management frames (Deauthentication/Disassociation) lack cryptographic signing, allowing threat actors to forge the AP's source MAC address. RF Jamming exploits the physical open-air medium by emitting high-power electromagnetic noise across standard wireless spectra.

🛡️ **GRC Auditor Perspective:** Enforce IEEE 802.11w Protected Management Frames (PMF) which cryptographically signs management frames; monitor spectrum analytics in the WIPS to detect and alert on localized intentional RF jamming.

⚠️ **How CompTIA Tests This:** Trigger: 'spoofed frames sent to force clients to disconnect and capture handshakes' -> Deauthentication Attack (Defense: 802.11w / PMF). Trigger: 'intentional radio frequency noise causing Denial of Service' -> RF Jamming.

📌 WPA2 vs. WPA3 (SAE & Forward Secrecy)

🏠 **Real-World Analogy:** WPA2-Personal relies on a Pre-Shared Key (PSK) where an attacker recording a device's initial handshake (the 4-way EAPOL exchange) can take the packet capture home and run billions of offline dictionary guesses without ever touching the network again. WPA3 eliminates this using SAE (Simultaneous Authentication of Equals / Dragonfly handshake): an active, zero-knowledge mathematical exchange where passive packet sniffers cannot crack keys offline. Furthermore, SAE provides Perfect Forward Secrecy, ensuring past intercepted sessions remain encrypted even if the master password is later compromised.

🔍 **Root Cause & Background:** The legacy WPA2 4-way handshake derives pairwise keys directly from a static passphrase without zero-knowledge proofs, exposing captured handshakes to high-speed offline dictionary cracking. WPA3 implements the Dragonfly handshake (SAE) and mandates 802.11w management frame protection.

🛡️ **GRC Auditor Perspective:** Enforce WPA3-Enterprise (or WPA3-Personal with SAE) across all access points; deprecate WPA2/WPA3 mixed transition modes that remain vulnerable to downgrade exploits; verify PMF enforcement.

⚠️ **How CompTIA Tests This:** Trigger: 'cryptographic feature in WPA3 protecting against offline password dictionary attacks' -> SAE (Simultaneous Authentication of Equals). Trigger: 'capturing four-way handshake packets to run a hashcat dictionary attack' -> WPA2 PSK vulnerability.

📌 WPS (Wi-Fi Protected Setup) Vulnerabilities

🏠 **Real-World Analogy:** WPS (Wi-Fi Protected Setup) PIN mode is like installing a 20-digit electronic lock on your front door, but adding a cheap 4-digit bicycle combination lock right beside it so guests can enter easily. An intruder ignores the complex main lock and cracks the trivial 4-digit lock in under two hours, unlocking the entire property.

🔍 **Root Cause & Background:** WPS simplifies onboarding using an 8-digit PIN. The protocol architecture verifies the first 4 digits separately from the last 3 digits (the 8th is a checksum). This design flaw reduces brute-force complexity from 100,000,000 possibilities to just 11,000 attempts, easily crackable within hours.

🛡️ **GRC Auditor Perspective:** Mandate the permanent disabling of WPS (Wi-Fi Protected Setup) across all enterprise and home-office access points in remote work security baselines.

⚠️ **How CompTIA Tests This:** Trigger: 'mechanism allowing device pairing via an 8-digit PIN susceptible to rapid brute forcing'. Answer: WPS. Recommended mitigation: Disable WPS.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Attacker deploys a wireless access point configured with an identical SSID and stronger signal to harvest user credentials	**Evil Twin**
Unauthorized wireless AP connected to the corporate wired infrastructure by an employee without IT authorization	**Rogue Access Point**
Spoofed wireless management frames transmitted to disconnect legitimate users and force reconnection to a malicious AP	**Deauthentication Attack**
Deliberate radio frequency interference overwhelming wireless frequencies to cause complete service disruption	**RF Jamming**
WPA3 handshake mechanism that prevents offline dictionary and rainbow table cracking against pre-shared keys	**SAE (Simultaneous Authentication of Equals)**
Standard that cryptographically signs management frames to prevent spoofing and deauthentication attacks	**IEEE 802.11w / PMF (Protected Management Frames)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

Employees at a credit union report that when they browse to the institution's public banking portal from the corporate network, they are taken to a convincing look-alike login page. Security verifies that the portal's records on the authoritative nameservers are correct, the web server was never compromised, and users on other networks reach the legitimate site. Many workstations rely on a shared upstream recursive resolver. What is the MOST likely cause of the redirection?

A) Domain hijacking at the registrar

B) Subdomain takeover of a dangling CNAME record

C) Forged DNS responses accepted into the recursive resolver's cache

D) Typosquatting of the portal's web address

QUESTION 2 · EXAM SCENARIO

On Monday morning, staff discover that the company's public website and corporate email are unreachable. Investigation shows the contact email on the registrar account received password-reset requests from a phishing campaign two days earlier, and public WHOIS now lists different registrant details and nameservers pointing to unknown infrastructure. The internal web servers and mail servers themselves were never accessed. Which attack BEST describes what happened?

A) Domain hijacking via a compromised registrar account

B) DNS cache poisoning of the company's internal resolver

C) DNS tunneling with command-and-control queries

D) Subdomain takeover of the MX record

QUESTION 3 · EXAM SCENARIO

A software vendor's support team receives complaints from customers who, after mistyping the product's download URL (transposing two letters), landed on an identical-looking page that delivered a malicious 'update' executable. Threat intelligence finds the look-alike domain was registered anonymously shortly after the product launch, and nothing on the vendor's own DNS or web infrastructure was altered. Which attack does this illustrate?

A) DNS cache poisoning

B) Typosquatting (URL hijacking)

C) Domain hijacking

D) Subdomain takeover

QUESTION 4 · EXAM SCENARIO

A DLP review shows no email attachments or cloud uploads leaving the network, yet firewall logs reveal a workstation sending thousands of TXT-record queries to a single external authoritative zone, each query carrying a long base32-encoded string under a unique subdomain and receiving large TXT responses. Daily DNS volume to that zone exceeds 1 GB. What is the MOST likely activity?

A) A DNS amplification DDoS attack reflected from the network

B) An accidental misconfigured zone transfer (AXFR)

C) A DNSSEC validation failure generating oversized responses

D) DNS tunneling used to exfiltrate data and maintain command-and-control

QUESTION 5 · EXAM SCENARIO

Following an incident in which a recursive resolver accepted forged replies that steered customers to an attacker's server, the security director wants a mechanism that lets resolvers cryptographically verify that responses for the organization's public zone are authentic and unmodified before using them. Which control should be implemented?

A) Lower the TTL of all public DNS records

B) Digitally sign the public zone using DNSSEC

C) Configure a wildcard record covering all subdomains

D) Enable open recursion on the public-facing resolver

QUESTION 6 · EXAM SCENARIO

A cloud engineering team decommissioned a marketing microsite hosted on a third-party static hosting service but forgot to remove the CNAME record pointing to it. Weeks later, customers report seeing attacker-controlled content, including malicious JavaScript, served at that subdomain; an external scan confirms the hosting endpoint can now be claimed by any new tenant. What BEST describes the exploited weakness?

A) A zone transfer exposed the entire zone to the attacker

B) The recursive resolver's cache was poisoned

C) A dangling DNS record enabling subdomain takeover

D) The registrar transfer lock was disabled

QUESTION 7 · EXAM SCENARIO

After confirming that malware exfiltrated a customer database through DNS queries sent directly to external authoritative servers, the security team must redesign the network's egress DNS. Which approach MOST effectively prevents endpoints from tunneling data through DNS queries?

A) Allow DNS egress (port 53 and DoT on 853) only to designated internal recursive resolvers, block direct external DNS, and monitor query volume and record types

B) Instruct all clients to use shorter TTL values to limit any poisoned cache entries

C) Enable recursion for untrusted external clients on the public-facing authoritative server

D) Convert all legacy TXT records into wildcard records to reduce query variety

QUESTION 8 · EXAM SCENARIO

Guests on the conference-room Wi-Fi are redirected to a phishing page when they visit the corporate benefits portal, while wired users in the main office are unaffected. Packet capture on the guest VLAN shows DNS replies arriving from the MAC address of an unknown laptop milliseconds before the genuine gateway resolver responds, mapping the portal to a foreign IP address. No registrar or authoritative records changed, and the corporate resolver's cache is clean. Which attack BEST matches these observations?

A) Cache poisoning of the organization's authoritative nameserver

B) Domain hijacking through stolen registrar credentials

C) DNS tunneling over TXT records

D) DNS spoofing by an on-path attacker on the guest network

QUESTION 9 · EXAM SCENARIO

A fintech startup is preparing its public launch, and its threat model identifies attackers registering misspelled versions of the brand's domain to phish early customers. Which proactive measure BEST reduces this typosquatting risk to the brand?

A) Publish DNSSEC signatures for the company's own zone

B) Register common misspellings, letter transpositions, and alternate TLDs of the brand

C) Require all customer browsers to resolve through DNS-over-HTTPS

D) Reduce the TTL on the brand's A and CNAME records

QUESTION 10 · EXAM SCENARIO

A company recovered from an incident in which an attacker used stolen registrar credentials to change the domain's nameservers, taking days to regain control of the domain. The CISO wants controls aimed specifically at preventing a recurrence at the registrar level. Which combination BEST addresses this risk?

A) Deploy DNSSEC signing and split DNS on the internal zones

B) Enable a wildcard record and shorten the TTLs of all records

C) Enable registrar transfer lock, enforce MFA on the registrar account, and monitor for unauthorized WHOIS or nameserver changes

D) Migrate DNS hosting to an open recursive resolver that accepts permissive dynamic updates

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Forged DNS responses accepted into the recursive resolver's cache

Because the authoritative zone data is correct and the problem only affects users who depend on the shared recursive resolver, the resolver must have accepted a forged reply and stored it (DNS spoofing/cache poisoning). Until the poisoned entry expires or the cache is flushed, clients are silently sent to the attacker's IP. Domain hijacking would affect all users worldwide because it changes records at the registrar level; typosquatting requires users to mistype the address; subdomain takeover involves a dangling record pointing to a claimable third-party resource, which is not the case here.

Question 2: Option A — Domain hijacking via a compromised registrar account

The attacker obtained registrar credentials and modified registrant information and nameservers, redirecting the domain's traffic and MX records to attacker-controlled infrastructure. This is a classic domain hijacking. Cache poisoning affects only resolver caches, not authoritative ownership; DNS tunneling hides data within queries for exfiltration or C2 and does not change WHOIS; subdomain takeover requires a dangling record pointing to a claimable service and would not take over the entire domain including MX.

Question 3: Option B — Typosquatting (URL hijacking)

Registering a misspelled variant of a legitimate domain to catch typo traffic and impersonate the brand is typosquatting, also called URL hijacking. Since the vendor's infrastructure was untouched, cache poisoning (a forged reply stored in a resolver's cache) and domain hijacking (registrar-level theft of the domain) do not apply. Subdomain takeover requires a dangling record in the victim's own zone, which is absent here.

Question 4: Option D — DNS tunneling used to exfiltrate data and maintain command-and-control

Encoding data into unique subdomains and carrying responses in TXT (or NULL) records is the signature of DNS tunneling, a technique attackers use to exfiltrate data and run C2 channels because DNS is rarely blocked. Amplification would show the network being used to flood a third party with spoofed-source queries, not structured query/response pairs; a zone transfer is a one-time TCP operation between servers, not repeated subdomain queries; DNSSEC validation failures produce SERVFAIL or bogus statuses, not megabytes of coordinated traffic.

Question 5: Option B — Digitally sign the public zone using DNSSEC

DNSSEC adds digital signatures (RRSIG/DNSKEY records) and a chain of trust from the root down to the zone, allowing validating resolvers to detect forged or tampered answers and reject them — the direct cryptographic defense against cache poisoning. Shorter TTLs only reduce how long a poisoned entry persists; wildcard records have no integrity function; open recursion increases exposure (including abuse for DDoS amplification) and does nothing to validate answers.

Question 6: Option C — A dangling DNS record enabling subdomain takeover

When a DNS record (often a CNAME) points to a third-party resource that has been deprovisioned but not claimed, an attacker can register that resource on the provider and serve content under the victim's subdomain — a subdomain takeover exploiting a dangling record. This lets attackers phish, steal cookies, or bypass same-origin expectations under a trusted hostname. A zone transfer would leak record data but not serve hostile content; cache poisoning is transient state in a resolver's cache; the transfer lock relates to registrar-level domain hijacking.

Question 7: Option A — Allow DNS egress (port 53 and DoT on 853) only to designated internal recursive resolvers, block direct external DNS, and monitor query volume and record types

Forcing every endpoint to resolve through controlled internal resolvers (while blocking direct port 53/853 access to the internet) creates a chokepoint where the team can log, inspect, and rate-limit queries and alert on the hallmarks of tunneling — heavy use of TXT/NULL records, long-encoded labels, and high query volume to a single zone. Shorter TTLs do not affect tunneling at all; enabling open recursion on an authoritative server invites amplification abuse; wildcard records do not constrain what an attacker can query.

Question 8: Option D — DNS spoofing by an on-path attacker on the guest network

A forged DNS reply racing ahead of the legitimate response from an unexpected MAC address on the same local segment is the hallmark of an on-path attacker (often using ARP spoofing) performing DNS spoofing in real time. Because authoritative data and caches are untouched, options involving poisoned caches or registrar changes do not fit, and nothing in the capture shows data being smuggled inside queries as in DNS tunneling.

Question 9: Option B — Register common misspellings, letter transpositions, and alternate TLDs of the brand

Defensive registration of likely typo variants (e.g., transposed letters, singular/plural, alternative top-level domains) removes the most attractive look-alike names from the market before attackers can claim them — the standard countermeasure to typosquatting. DNSSEC protects the integrity of the company's own zone but does nothing about third-party registrations; DNS-over-HTTPS affects transport of queries, not which domains exist; TTL values are irrelevant to domain availability.

Question 10: Option C — Enable registrar transfer lock, enforce MFA on the registrar account, and monitor for unauthorized WHOIS or nameserver changes

The registrar account was the attack vector, so controls belong there: a transfer/registry lock blocks unauthorized nameserver or registrant changes, MFA defeats credential theft even if the password is phished, and monitoring WHOIS/nameserver changes gives early warning so the domain can be reclaimed quickly. DNSSEC and split DNS protect response integrity and internal naming, not registrar access; wildcard records and TTLs are unrelated to hijacking; open recursion with permissive dynamic updates would actually expand the attack surface.